

InjectaBLE:
**Injecting malicious traffic into established
Bluetooth Low Energy connections (2021)**

Sean Crowley
Dr. Le Guan, CS 8965



Mary Frances Early
College of Education
UNIVERSITY OF GEORGIA

Presentation Structure

1. Introduction
2. Related Work
3. BLE Intro
4. InjectaBLE Attack Challenges
5. InjectaBLE Attack
6. InjectaBLE Use Cases
7. Proposed Mitigation
8. Bluetooth Specification v5.3 (fix)
9. Conclusion



Introduction



Mary Frances Early
College of Education
UNIVERSITY OF GEORGIA

IoT Introduction

IoT is everywhere!

- fridges, smartwatches, coffee makers, etc.

Rely on microcontrollers & radios for connectivity.

Bluetooth Low Energy (BLE):

- Major communication protocol
- Low-power & efficient for local communication
 - Peer-to-peer (no networking required)

Bluetooth Low Energy (BLE) Protocol

Protocol: **Standard set of rules for communication**

BLE follows the **Bluetooth Core Specification**

BLE is an **energy efficient** version of the Bluetooth protocol

- Sleep / Wake cycles to conserve energy

InjectaBLE Target:

- **Bluetooth Core Specification** versions **v4.0** to **v5.2**
- Includes vulnerable BLE Specification
- Version v5.3 *unintentionally* mitigates the InjectaBLE issue

Related Work



Mary Frances Early
College of Education
UNIVERSITY OF GEORGIA

Related Work

BLE grew in popularity, so security researcher got to work attacking the specification & certain implementations.

Previous Goals:

- Passive Attack:
 - Learn to **sniff BLE connection** packets (Difficult due to channel hopping algorithms)
- Active Attacks:
 - Jamming
 - Hijacking
 - Man-in-the-Middle

Related Work - Passive (Sniffing)

Issue: Channel Hopping during an established connection.

- [19] Insight into channel hopping parameters from the start connection packet.
- [17] Sniffle, improvements & detects device presence:
 - If data is broadcast on a specific channels,
 - Then there is a device on that channel.

Two Hopping Algorithms:

- Channel Selection Algorithm #1: modular addition
- Channel Selection Algorithm #2: pseudo-random

Summary: Bruteforce BLE packet sniffing!

Related Work - Active

Jamming [6, 9]:

- BTLEJack: Disconnect master & Sync with slave (become master)
- Issue: **Invasive** & fails to hijack slave role

Man-in-the-Middle [7, 15]:

- GATTacker: Spoof slave advertisements & become slave device
- BTLEJuice: Connect to slave & connect to master (as they attempt)
- Issue: **Only possible prior to connection establishment**

Authentication Attacks:

- Not Super Relevant as they attack specific BLE implementations.

Related Work (limitations)

Limitations:

- **Active** attacks occur **before** BLE connection is established.
- Highly invasive techniques (ex: jamming)

Two papers [19, 21] mention:

- A non-invasive injection-based attack in an BLE established connection is **theoretical & hard**
- “dealing with **race conditions** is complex and would require high performance hardware”

Obfuscation != Security

InjectaBLE shows **it is possible** and uses a race condition to its advantage.

What did InjectaBLE Prove?

InjectaBLE stealthily **injects malicious packets** into an **already established** BLE connection.

Results:

- Trigger device behavior (remotely control BLE device)
- Hijack **ANY** role in the BLE connection
- Perform a MitM attack at **ANY** point during a BLE connection

Affect:

- All devices using BLE v4.0 to v5.2 regardless of manufacturer



Bluetooth Low Energy

(The Basics™)



Mary Frances Early
College of Education
UNIVERSITY OF GEORGIA

BLE Basics

BLE is a lightweight / low energy version of Bluetooth

Device POV:

- **Controller:** Handles low-level Bluetooth
 - Radio Communication
- **Host:** Manages high-level tasks
 - Advertising
 - Listening
 - Connection

Host & Controller are on a single device!

Any given BLE application has a Host & Controller to make BLE communication easier for the programmer.

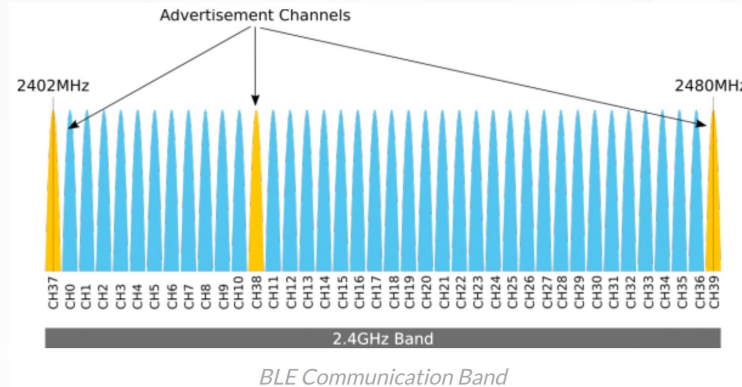
BLE Physical Layer

Industrial, **Scientific**, **Medical**
Radio Frequencies

BLE operates in the 2.4 - 2.5 GHz ISM Band

BLE has 40 channels for data transmission

- Channels [37, 38, 39] **advertising** mode
- Channels [0-36] **connected** mode



BLE Communication

ATT (Attribute Protocol):

- Client $\longleftrightarrow$ Server model for exchanging data.

GATT (Generic Attribute Profile):

- Organizes ATT into ***generic profiles*** or classes
 - Heart rate monitor
 - Battery Info
 - Thermometer
- Each profile has associated data fields

BLE Device Roles

Generic Access Profile: Outlines 4 different **device roles**.

Two Roles for **Connected Mode**:

- Peripheral/Slave Role (smartwatch, smart bulb)
- Central/Master Role (phone)

BLE Link Layer Basics

Basic Frame Format: **Notice** the **CRC**

TABLE I: Frame format for *LE 1M*

Preamble	Access Address	Protocol Data Unit (PDU)	CRC
1 byte	4 bytes	variable	3 bytes

CONNECT_REQ Frame:

Notice the **WinSize**, **WinOffset**, **Hop Interval**, and **SCA**

TABLE II: CONNECT_REQ PDU

Init. addr.	Adv. addr.	Access addr.	CRCInit	WinSize	WinOffset	Hop interval	Latency	Timeout	Channel Map	Hop Increment	SCA
6 bytes	6 bytes	4 bytes	3 bytes	1 byte	2 bytes	2 bytes	2 bytes	2 bytes	5 bytes	5 bits	3 bits

BLE Connection Event

Start of Connection Event (anchor point): t_n
Inter-Frame Spacing (wait to respond): $150\mu\text{s}$
Connection Event Length: $d_{\text{connInterval}}$

NOTE:
The connection events are
on different channels
Recall: channel hopping

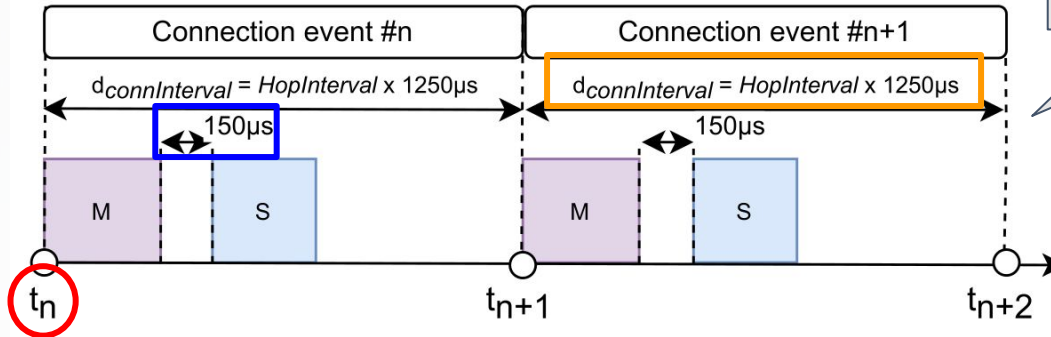


Fig. 1: Two consecutive *connection events*

InjectaBLE Attack Challenges



Mary Frances Early
College of Education
UNIVERSITY OF GEORGIA

InjectaBLE Attack Challenges

Challenge 1 (C1): Identify when to inject the malicious frame

Challenge 2 (C2): What should the malicious frame contain?

Challenge 3 (C3): Prove the attack was successful

InjectaBLE Setup Conditions

1. Attacker **within radio range** of target
2. Attacker **uses BLE 4.0 or BLE 5.0 device**
3. Attacker can
 - a. Passively **sniff the traffic**
 - b. Actively craft / send spoofed packets on BLE channels
4. Attacker does not need to exploit ANY vulnerabilities on the target device (i.e. **Attacking Specification**)

InjectaBLE Setup Conditions (cont.)

1. Target Established Connection should not be using encrypted communications
 - a. If they are, the attack boils down to a simple DOS attack. (affects CIA: availability)
 - b. [26] “the majority of BLE communications are poorly or not at all encrypted today”

InjectaBLE Attack



Mary Frances Early
College of Education
UNIVERSITY OF GEORGIA

Window Widening Flaw

Window Creation Steps:

1. Slave expects **first connection evt packet** from Master @ t_{n+1}
2. Slave goes to sleep
3. Slave wakes up at t_{n+1} **BUT** its *sleep clock drift* since t_n is unknown
4. Therefore, **slave listens for a time interval**

Slave Receive Window (w):

- $(t_n - w) < t_n < (t_n + w)$

Can't trust
own Sleep
Clock

Normal Window Widening

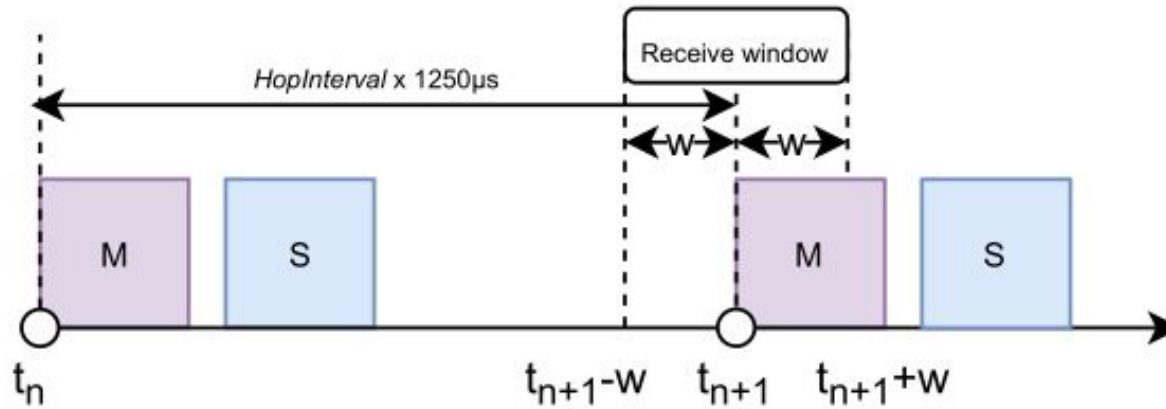


Fig. 4: *Window widening for a Slave receiving the next connection event*

Abused Window Widening (racing)

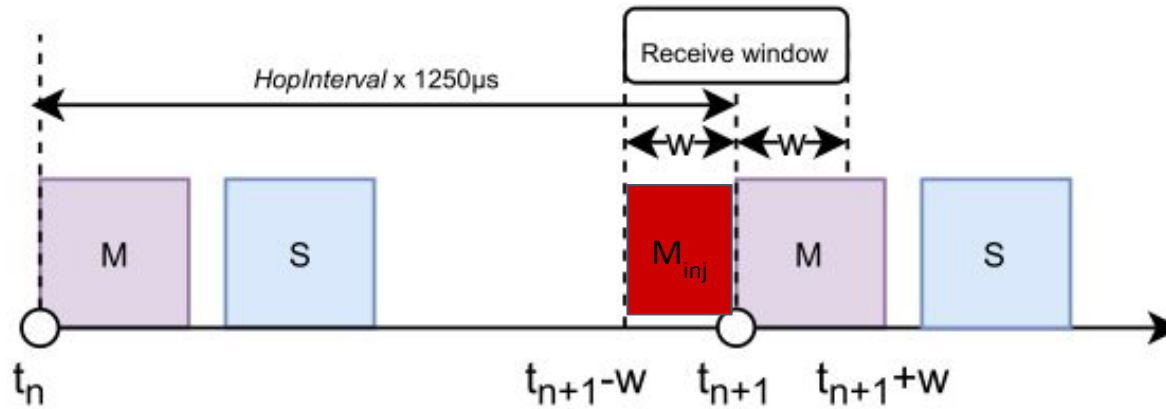


Fig. 4: *Window widening for a Slave receiving the next connection event*

Injection Requirements

Sniff BLE Connection (Find: 'injection point')

- Clock Inaccuracy (Creates injection window)
- Window Widening (Increase injection window size)

Injecting Malicious frame:

- Abuse the resulting 'race condition' from window widening
- Inject packet before Master & Within the receive window
- Checksum is correct (CRC)

Verify the injection was successful:

- Correct Slave Response

InjectaBLE Calculates Injection Point

Window Widening (Increase Window size):

- SCA_m - Sleep Clock Accuracy (master)
- SCA_s - Sleep Clock Accuracy (slave)
- t_{next} - Start time of NEXT connection event
- t_{last} - Start time of LAST connection event

$$w = \frac{SCA_M + SCAS}{1000000} \times (t_{nextAnchor} - t_{lastAnchor}) + 32\mu s \quad (4)$$

$(t_{next} - t_{last})$: Interval between two connection events
that the **slave actually handles**

Restated

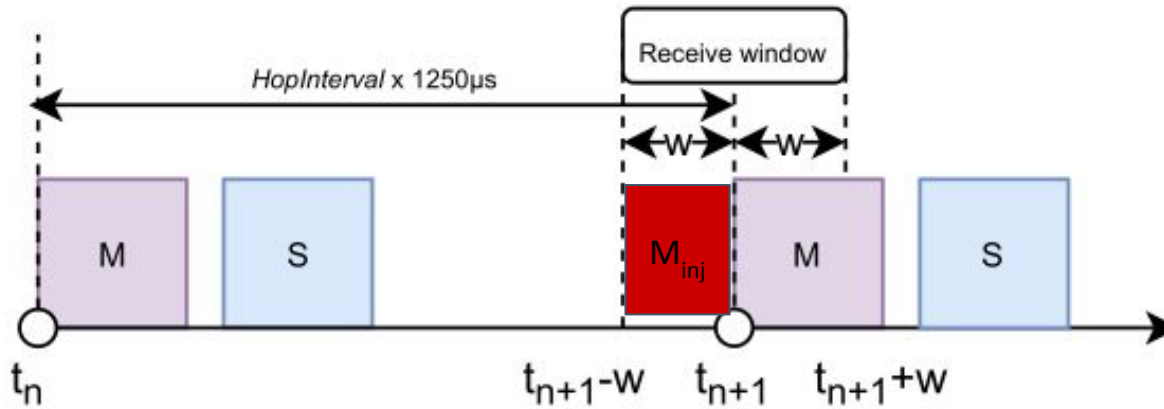


Fig. 4: *Window widening for a Slave receiving the next connection event*

Potential Injection Scenarios

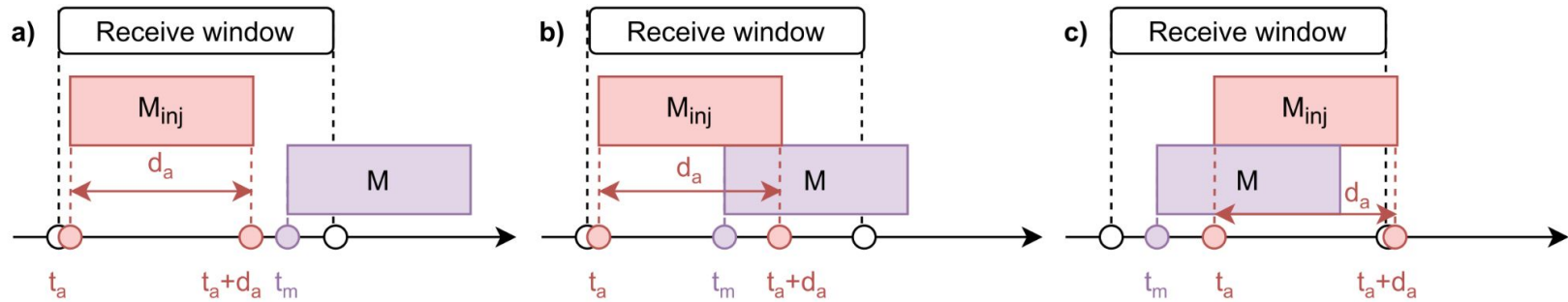


Fig. 5: Three possible outcomes of an injection attempt

Validate Injection

Injection Success, if:

- Slave responds 150 μ s after our malicious packet
- Slave responds with the correct Sequence Numbers

InjectaBLE Use Cases



Mary Frances Early
College of Education
UNIVERSITY OF GEORGIA

InjectaBLE Attack Use Cases

Four attack scenarios:

1. Use slave device functionality (ATT cmds):
 - a. Like previous research but doesn't require jamming
 - b. Ex: Turn ON / OFF smart lamp
2. (new) Hijacking Slave Role
 - a. Inject LL_TERMINATE_IND packet in recv window
 - b. Slave **exits** connection
 - c. Master **unaware**
 - d. Attacker **mimics slave** (responds 150μs later)

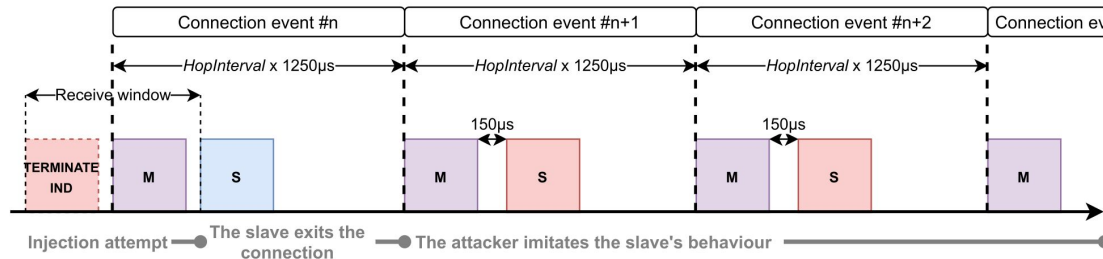


Fig. 6: Description of the slave hijacking

InjectaBLE Attack Use Cases (cont.)

1. Hijacking the Master
 - a. Previous research [9], proposed the BTLEJack Tool to hijack master role but was invasive
 - b. InjectaBLE is more discrete & reliable

InjectaBLE Attack Use Cases (cont.)

1. Man-in-the-Middle attack:
 - a. Previous research was limited (only possible @ the beginning of connection)
 - b. InjectaBLE can discreetly insert itself in the middle of two devices at **any point in the established connection.**
 - c. Idea:
 - i. Attacker forges Connection Update packet
 - ii. Slave updates its connection timing with new timing
 - iii. Master does not
 - iv. Attacker syncs with both device communication times

Man-in-the-Middle Example

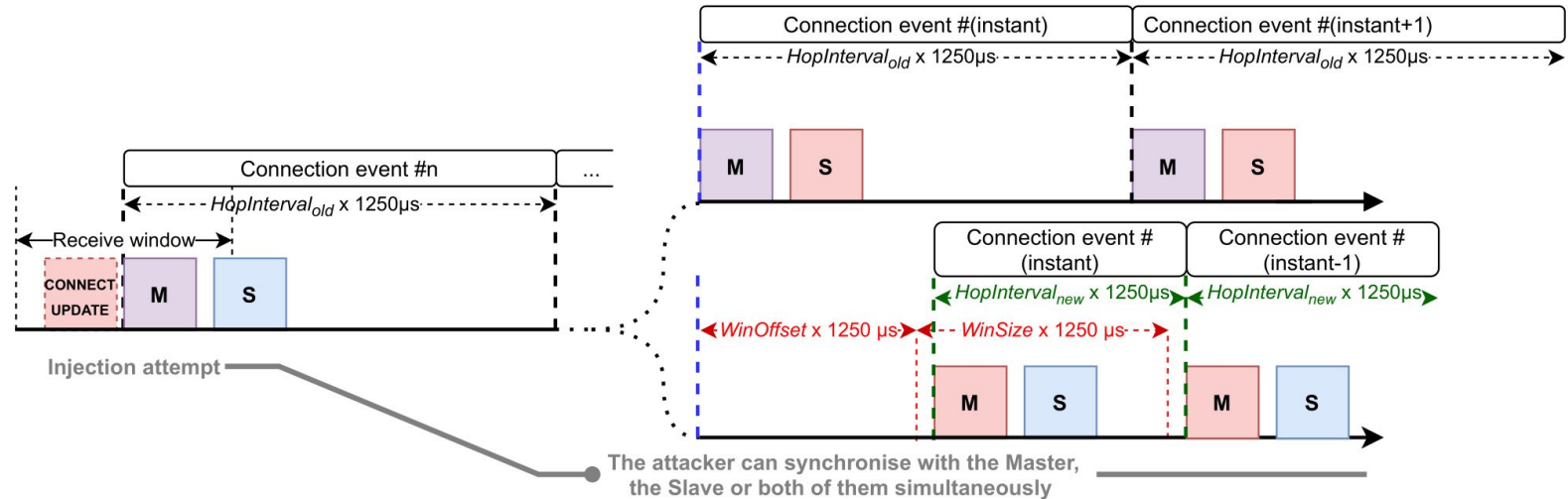


Fig. 7: Description of the Man-in-the-Middle attack

Proposed Mitigation



Mary Frances Early
College of Education
UNIVERSITY OF GEORGIA

Potential InjectaBLE Mitigation

1. Update Bluetooth specification to tighten the rcv window
 - a. Bluetooth actually did! (but not cause of InjectaBLE)
2. Enable Encryption
 - a. If ALL frames are ciphered, harder to sniff packets
 - b. Still vulnerable to DOS attacks
3. Intrusion Detection System
 - a. Monitor BLE link layer traffic for double frame detection

Bluetooth Specification v5.3 (fix)

InjectaBLE Paper Release: **June 21st, 2021**

Bluetooth Specification Update: **July, 2021**

Efficiency Improvement with v5.3:

- Subrating (more frequent clock sync)
- Dynamically share device Sleep Clock Accuracy

Trade off conclusion:

- Energy(Larger Listen Window) > Energy(freq. clock syncs)

Bluetooth acknowledged InjectaBLE the day the paper was released.

Bluetooth Specification v5.3 (fix)

Pre-5.3 devices didn't dynamically share their SCAs devices always assumed worst case drift and had HUGE window times when they were listening.

Bluetooth saw this BIG LISTENING WINDOW as inefficient so they setup more frequent syncs (subrating) & started dynamically sharing changes to their Sleep Clock Accuracy so that both devices could account for one another's drift more accurately. Meaning, both devices could wake-up on time more accurately & not have to listen for as long... therefore, improving efficiency and unintentionally fixing the InjectaBLE issue.

Questions?



Mary Frances Early
College of Education
UNIVERSITY OF GEORGIA

References

[19] M. Ryan, "Bluetooth: With Low Energy comes Low Security," 2013.

[17] S. Qasim Khan, "Sniffle: A sniffer for Bluetooth 5 (LE)," 2019, <https://hardwear.io/netherlands-2019/presentation/sniffle-talk-hardwear-lo-nl-2019.pdf>.

[6] S. Bräuer, A. Zubow, S. Zehl, M. Roshandel, and S. Mashhadi-Sohi, "On practical selective jamming of bluetooth low energy advertising," in 2016 IEEE Conference on Standards for Communications and Networking (CSCN), 2016, pp. 1–6.

[9] —, "You'd better secure your BLE devices or we'll kick your butts!" 2018, [https://media.defcon.org/DEF CON 26/DEF CON 26 presentations/Damien Cauquil - Updated/DEFCON-26-Damien-Cauquil-Extras/](https://media.defcon.org/DEF%20CON%2026/DEF%20CON%2026%20presentations/Damien%20Cauquil%20-%20Updated/DEFCON-26-Damien-Cauquil-Extras/).

[7] D. Cauquil, "BtleJuice, un framework d'interception pour le Bluetooth Low Energy," <https://www.slideshare.net/NetSecureDay/nsd16-btle-juice-un-framework-dinterception-pour-le-bluetooth-low-energy-damien-cauquil>, 2017.

[15] S. Jasek, "Gattacking Bluetooth Smart Devices," 2017.

[21] A. Santos, J. Filho, A. Silva, V. Nigam, and I. Fonseca, "Ble injection-free attack: a novel attack on bluetooth low energy devices," Journal of Ambient Intelligence and Humanized Computing, 09 2019

26] C. Zuo, H. Wen, Z. Lin, and Y. Zhang, "Automatic fingerprinting of vulnerable ble iot devices with static uuids from mobile apps," in Proceedings of the 2019 ACM SIGSAC Conference on Computer and Communications Security, 2019, pp. 1469–1483.

Bluetooth Acknowledgement of InjectaBLE: <https://www.bluetooth.com/learn-about-bluetooth/key-attributes/bluetooth-security/injectable/>

CVE-2021-31615: <https://nvd.nist.gov/vuln/detail/CVE-2021-31615>

